NovaPay Digital Bank

Zero-Downtime CI/CD Pipeline with Compliance Gates

Technology Risk Committee — Architecture Approval Presentation

Prepared by: DevOps Lead | Track: Project 1A — DevOps & Cloud Engineer

Problem Statement

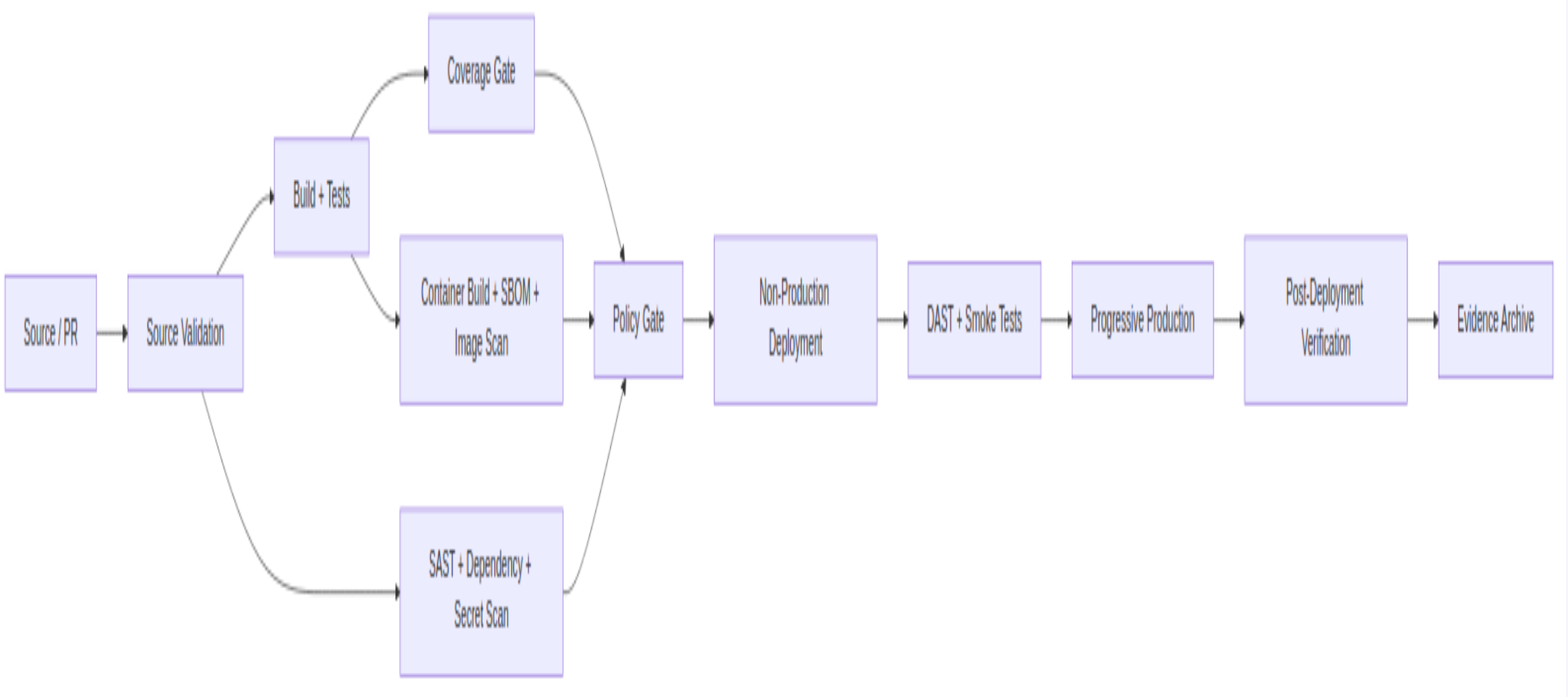
Current state of NovaPay Digital Bank

4.5 hrs	14 days	17	0
Mean Time to Recovery	Deployment cycle (fortnightly)	Open RBI audit non-conformances	Automated compliance scans

- Manual SSH deployments to production — no CI/CD pipeline exists today
- 3 production incidents in Q4 2025 traced directly to untested code deployments
- Database migrations performed manually during 2 AM maintenance windows
- Zero observability — incidents are detected by customers, not by internal systems
- The CTO has allocated a 90-day remediation window; this pipeline design is proposed for approval today

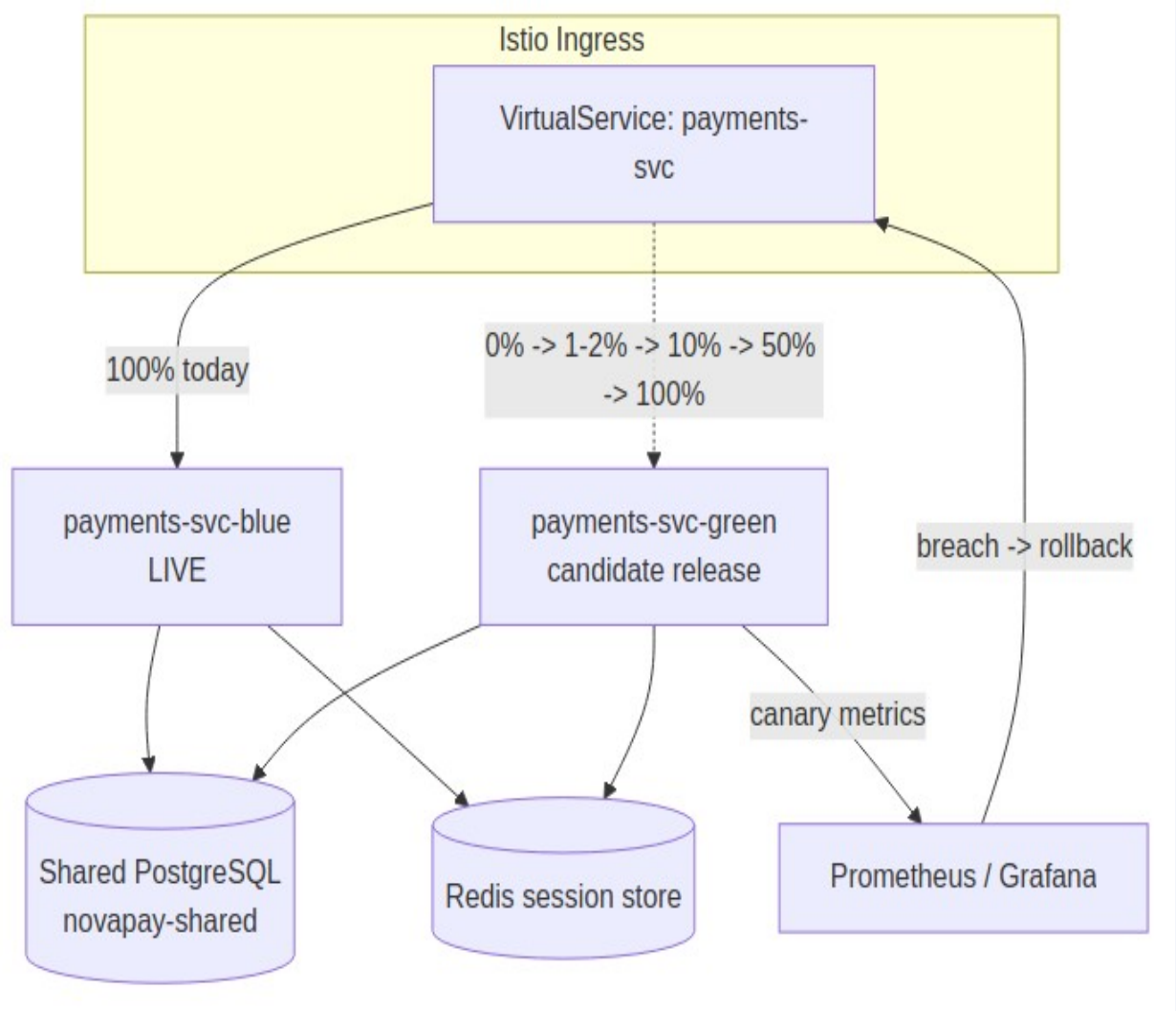
Solution Architecture

Eight-stage pipeline, GitHub Actions + Kubernetes/Helm target



Zero-Downtime Deployment Strategy

Blue-Green cutover + progressive canary rollout



Phase	Traffic	Gate
Canary	1-2%	err<0.1%, p99<200ms
Early Adopter	5-10%	err<0.05%
Expansion	25-50%	all SLOs met
Full Rollout	100%	24h bake stable

Automated rollback: Category A triggers (5xx>5%, health-check fail x3) revert traffic in under 60s with zero human step.

Zero-Downtime Database Migration

Expand-contract pattern — 5 phases, no table locks

- Phase 1 — EXPAND: add new nullable columns, fully backward compatible with the currently deployed app version
- Phase 2 — Deploy v(N): dual-write to old and new columns, reads still from the legacy column
- Phase 3 — MIGRATE: throttled, idempotent async backfill of historical rows (batch size 2,000, auto-abort if latency degrades >20%)
- Phase 4 — Deploy v(N+1): reads and writes move exclusively to the new columns
- Phase 5 — CONTRACT: drop the legacy column — irreversible, requires DBA + Release Manager + CAB sign-off

Every phase is independently deployable. An application rollback (v(N+1) -> v(N)) never hits a missing-column error, because every intermediate schema state supports both app versions simultaneously.

Compliance Gate Mapping

RBI Master Direction + PCI-DSS v4.0 — automated, not manual checklists

Gate	Threshold	RBI	PCI-DSS
SAST	0 Crit, <=2 High, cov>=80%	5.1	6.2
Secret scan	0 verified secrets	5.4	6.3
Dependency/container	0 Crit, High @ CVSS>=8.0	5.1, 7.2	6.3, 11.3
Policy-as-code (6 gates)	all Rego policies pass	4.3, 5.4	6.4, 2.2
Change mgmt / approvals	2 reviews, no self-approve	4.2, 4.3	6.5
Deploy verification	smoke + health pass	6.1, 6.3	6.5, 10.2

Full mapping detail: docs/03-compliance-gates/compliance-gates.md

Segregation of Duties

Enforced by tooling, not policy documents

- Git-level: CODEOWNERS + branch protection — developers cannot approve or merge their own pull requests
- IAM-level: developers hold zero standing production credentials
- Deployment-trigger-level: nobody runs kubectl apply against production directly — deploys are GitOps-driven and require Release Manager + SRE Lead approval
- Database-level: /database/migrations changes route to the DBA team via CODEOWNERS; the irreversible Contract-phase migration additionally requires Change Advisory Board sign-off
- Audit-level: every approval and policy decision is logged with actor identity — RBI Section 6.1 and PCI-DSS 10.2 in one trail

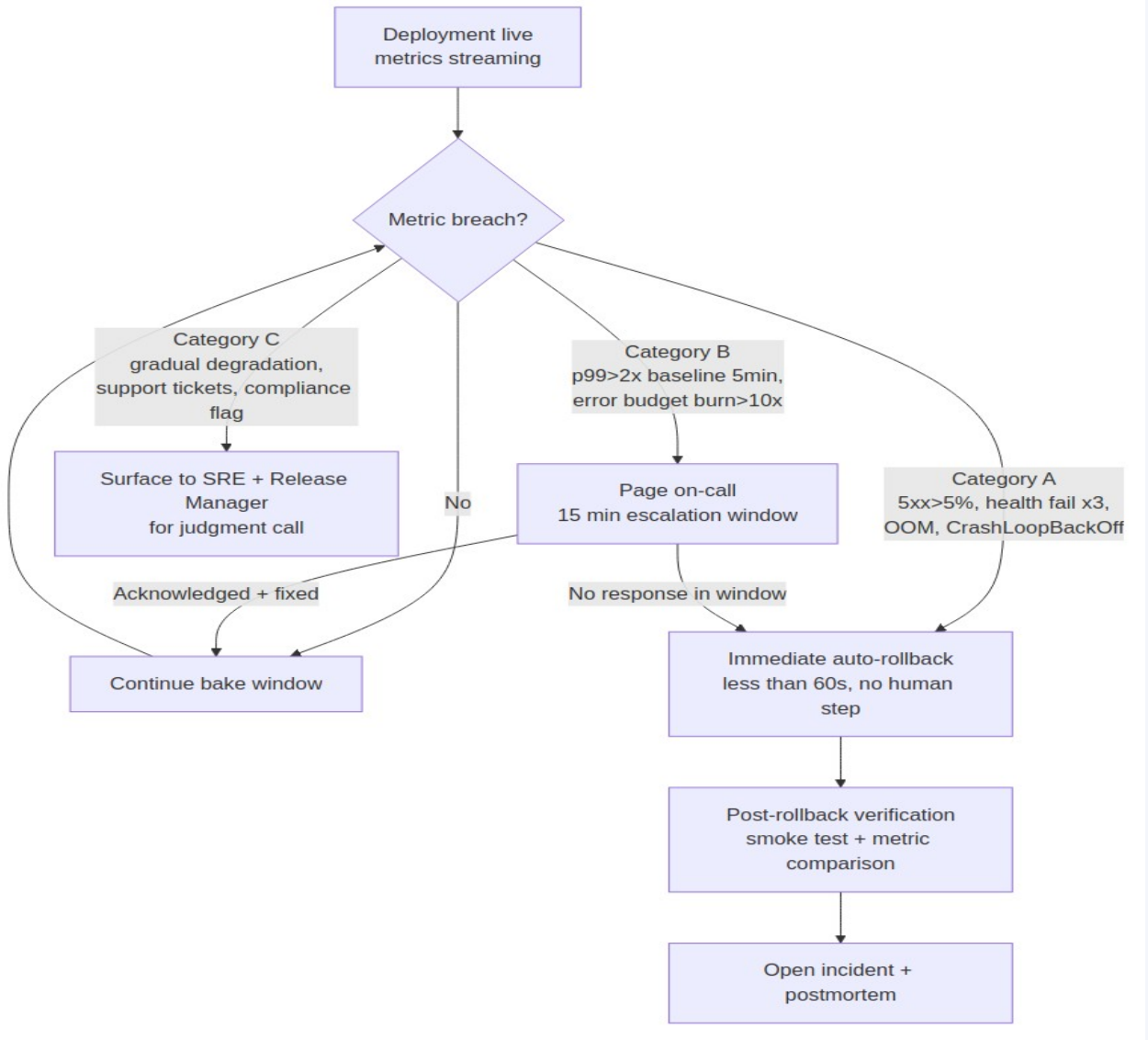
Rollback & Incident Response

Three-category trigger taxonomy

Category A — Immediate
< 60s, zero human step

Category B — Escalated
< 15 min, page on-call first

Category C — Manual
Surfaced for SRE/RM judgment



Observability & DORA Metrics

DORA Metric	Elite Target	Measurement
Deployment Frequency	Multiple per day	Count of prod deploys/day
Lead Time for Changes	< 1 hour	Commit -> prod deploy timestamp diff
Change Failure Rate	< 5%	(Rollbacks + hotfixes) / total deploys
MTTR	< 1 hour	Detection -> resolution duration

- Dashboards: Engineering (real-time ops), Management (weekly executive), Regulatory (audit-ready compliance evidence)
- Prometheus + Grafana for metrics; alerting routed by severity with defined escalation paths

Risk Mitigation — Lessons Applied

From real-world outages to NovaPay pipeline controls

Incident	Root Cause	NovaPay Control
Knight Capital (2012)	Manual, unverified multi-server deploy	Automated deploy + post-deploy version verification
YES Bank (2020)	No observability, manual pipeline	Automated compliance gates + real-time monitoring
Cloudflare (2019, 27 min)	Rollback coupled to failing control plane	Rollback operates at the mesh layer, independent of app health

Note: the Cloudflare case study's stated duration was corrected from 21 to 27 minutes — see ERRATA.md Error 2.

Implementation Roadmap

90-day remediation window

- Weeks 1-2: Pipeline stages 1-4 (source, build, SAST, dependency scan) live in CI for all services
- Weeks 3-5: Policy-as-code gates, secrets management, environment promotion workflow (dev -> staging -> pre-prod -> prod)
- Weeks 6-9: Blue-green + canary deployment integration (Istio), expand-contract migration tooling (pgroll)
- Weeks 10-12: Full observability stack, rollback automation, incident playbook drills
- Week 13: Technology Risk Committee final sign-off and production cutover

Request for Approval

- Approve the 8-stage pipeline architecture as the standard for all NovaPay services
- Approve the compliance gate mapping as satisfying RBI Master Direction and PCI-DSS v4.0 automated-control requirements
- Approve the 90-day implementation roadmap

Q&A